

SOC INCIDENT RESPONSE PLAYBOOK

Cybersecurity Operations | Phishing & Malware Incident Response

Authored by: Akorede Michael Alokun
Role: SOC Analyst | Security Operations
| Classification: Confidential | June 2026

1. Purpose & Scope

This playbook defines the step-by-step process for detecting, analyzing, containing, and recovering from cybersecurity incidents in a Security Operations Center (SOC) environment. It is designed to guide SOC Analysts through structured incident response with consistency and speed.

Scope covers:

- Phishing email incidents
- Malware infections and ransomware alerts
- Unauthorized access and privilege escalation
- Data exfiltration indicators
- Suspicious network traffic and C2 communications

2. Incident Severity Classification

All incidents must be classified before response begins. Use the matrix below to assign severity:

Severity	Level	Description	Response SLA
Critical	P1	Active breach, ransomware, CEO fraud, data exfiltration in progress	15 minutes
High	P2	Confirmed malware, successful phishing with credential harvest	1 hour
Medium	P3	Suspicious login, isolated phishing	4 hours

Severity	Level	Description	Response SLA
Low	P4	attempt, malware quarantined Spam, false positive alerts, minor policy violations	24 hours

3. Incident Response Phases

Phase 1: Detection & Identification

Sources for initial detection:

- SIEM alerts (Splunk / ELK) — correlate events across log sources
- Endpoint Detection & Response (EDR) tool alerts
- User-reported emails via security mailbox
- IDS/IPS triggered rules
- Threat Intelligence feed matches

Initial identification steps:

1. Log into SIEM and search for triggered alert rule
2. Pull raw logs: source IP, destination IP, timestamp, user account
3. Cross-reference IP/domain/hash in VirusTotal and Any.run
4. Check MITRE ATT&CK for the identified TTP pattern
5. Assign incident severity using the matrix in Section 2
6. Open an incident ticket and document initial findings

Phase 2: Containment

Containment actions depend on the severity level. Execute immediately to limit damage:

P1/P2	Immediately isolate affected host from network. Disable compromised user account. Block IOC (IP/domain/hash) at firewall and proxy. Notify Incident Manager.
P3	Quarantine suspicious file via EDR. Reset user password. Monitor account for further anomalies. Escalate if new IOCs discovered.
P4	Document and monitor. No immediate containment required unless situation escalates.

Phase 3: Eradication

After containing the threat, remove all artifacts:

7. Identify all affected systems using SIEM lateral movement queries
8. Remove malware using EDR — run full scan on all affected hosts
9. Delete malicious files, registry keys, scheduled tasks created by attacker
10. Revoke all sessions and tokens for compromised accounts
11. Patch the exploited vulnerability or close the attack vector
12. Re-image host if full compromise is confirmed (ransomware, rootkit)

Phase 4: Recovery

Restore systems to normal operation with validation:

13. Restore from last known clean backup (verify backup integrity first)
14. Monitor restored system for 24-48 hours via SIEM watchlist
15. Verify no persistence mechanisms remain (autorun, scheduled tasks, startup)
16. Re-enable user account only after password reset and MFA confirmation
17. Notify stakeholders of resolution and expected return to full operations

Phase 5: Post-Incident Review

Within 72 hours of incident closure:

18. Write a formal Incident Report (timeline, root cause, impact, IOCs)
19. Conduct lessons learned meeting with relevant teams
20. Identify detection gaps and propose new SIEM correlation rules
21. Update this playbook if new response patterns were identified
22. Submit IOCs to threat intelligence sharing platforms (MISP, FS-ISAC)

4. Phishing-Specific Response

4.1 Email Triage Checklist

- Check sender domain — does it spoof a legitimate domain?
- Inspect email headers: SPF, DKIM, DMARC results
- Extract and detonate any URLs in a sandbox (Any.run)
- Analyze attachments: submit hash to VirusTotal
- Check if other employees received the same email (email gateway logs)
- Identify if any recipient clicked the link or opened the attachment

4.2 Phishing MITRE ATT&CK Mapping

Tactic	Technique	ID	Detection Source
Initial Access	Phishing: Spearphishing Link	T1566.002	Email Gateway, Proxy Logs

Tactic	Technique	ID	Detection Source
Execution	User Execution: Malicious Link	T1204.001	EDR, Browser Logs
Credential Access	Input Capture: Keylogging	T1056.001	EDR Alert
Exfiltration	Exfil Over Web Service	T1567	Network Firewall, DLP
Command & Control	Application Layer Protocol	T1071	DNS Logs, SIEM

5. Escalation Matrix

Use this matrix to determine when and to whom to escalate:

Condition	Escalate To	Channel	Time Limit
Active ransomware spreading	CISO + Senior SOC Analyst	Phone + Ticket	Immediate
Confirmed credential compromise	SOC Lead + IT Admin	Slack + Ticket	30 minutes
Multiple hosts affected	Incident Response Team	War Room Bridge	1 hour
Regulatory breach (PII/PCI data)	Compliance + Legal	Email + Ticket	2 hours
Suspected insider threat	HR + Management	Confidential email	4 hours

6. Key Tools Reference

Tool	Purpose	Access
Splunk / ELK Stack	Log correlation, alert investigation, threat hunting	SIEM Console
VirusTotal	File/URL/IP reputation lookup	virustotal.com
Any.run	Interactive malware sandbox analysis	any.run
Wireshark	Packet capture and network traffic analysis	Local install / Network tap
MITRE ATT&CK Navigator	TTP mapping and adversary tracking	attack.mitre.org
EDR Console	Endpoint isolation, process tree analysis, hunting	EDR Dashboard

7. Incident Documentation Template

Every incident must be documented using this structure:

Field	Details
Incident ID	INC-YYYY-MMDD-XXX
Date/Time Detected	
Date/Time Reported	
Severity	P1 / P2 / P3 / P4
Incident Type	Phishing / Malware / Unauthorized Access / Other
Affected Systems	Hostname(s), IP(s)
Affected Users	Username(s), Department
IOCs Identified	IPs, domains, file hashes, email addresses
MITRE ATT&CK TTPs	Tactic: Technique (ID)
Actions Taken	Containment, eradication, recovery steps
Root Cause	
Business Impact	
Lessons Learned	
Analyst Name	

— End of Document —